

Práctica de pareja: recuperación de contraseñas y auditoría WPA2 con Hashcat

Módulo de Seguridad Informática — Kali Linux

Objetivo

Esta práctica se realiza en parejas. Trabajaréis con Hashcat para comprobar cómo la elección de una contraseña y el contenido de un diccionario afectan a la posibilidad de recuperarla, tanto en hashes MD5 como en una autenticación WPA2 real capturada en un punto de acceso creado por vosotros mismos.

Requisitos previos

- Un equipo con Kali Linux (máquina física o virtual) con Hashcat, aircrack-ng/iw y hextools instalados.
- Un teléfono móvil (cualquiera de la pareja) para crear el punto de acceso de la práctica.
- Un segundo dispositivo (otro móvil, tablet u ordenador) para conectarse al punto de acceso.
- El diccionario rockyou.txt (incluido en Kali en /usr/share/wordlists/rockyou.txt.gz; descomprimirlo con gunzip).

Parte 1. Ataque por diccionario a hashes

1. Crear las contraseñas

Crea 5 contraseñas reales, de mas a menos complejidad, sería interesante usar vuestro nombre, apellido, año actual, año de nacimiento... Y no hacerlas extremadamente largas, aunque podéis poner alguna que sea larga y/o complicada.

2. Crear los hashes

Genera un hash MD5 de cada contraseña. En Kali puedes usar, por ejemplo:

```
echo -n "casa" | md5sum
```

Guarda únicamente los hashes (uno por línea, sin la contraseña ni el nombre del archivo) en un archivo llamado:

```
hashes.txt
```

3. Crear vuestro propio diccionario

Crea un archivo llamado:

```
diccionario.txt
```

Introduce aproximadamente 20–30 posibles contraseñas.

3.1 Generar variaciones automáticamente con reglas de Hashcat

En lugar de escribir las 20-30 variaciones a mano, podéis partir de unas pocas palabras base (por ejemplo el nombre de vuestro compañero, el año de nacimiento, el apellido, año actual, lugar de vacaciones...) y dejar que Hashcat genere automáticamente un montón de variaciones típicas (mayúsculas, números al final, sustituciones tipo leetspeak, etc.) aplicando un archivo de reglas sobre esas palabras:

```
# palabras.txt contiene una palabra base por línea
hashcat --stdout -r /usr/share/hashcat/rules/best64.rule palabras.txt >
diccionario2.txt
```

El parámetro -r indica el archivo de reglas que se aplica a cada palabra; best64.rule es un conjunto de 64 reglas ya incluido en Kali (poner mayúscula inicial, añadir dígitos, invertir la palabra, sustituir letras por símbolos, etc.). Kali incluye otros conjuntos de reglas en /usr/share/hashcat/rules/ con distinto nivel de agresividad.

4. Intentar recuperar las contraseñas

Utiliza Hashcat para atacar los hashes utilizando vuestros diccionarios:

```
hashcat -m 0 hashes.txt diccionario.txt
```

Cuando termine, consulta las contraseñas recuperadas:

```
hashcat -m 0 hashes.txt --show
```

Anotad:

- Qué contraseñas se han recuperado.
- Cuáles no.
- Por qué creéis que ocurre.

Parte 2. Uso de un diccionario grande

Descomprime y utiliza ahora el diccionario rockyou.txt:

```
gunzip -k /usr/share/wordlists/rockyou.txt.gz
```

Repite el ataque contra los mismos hashes:

```
hashcat -m 0 hashes.txt /usr/share/wordlists/rockyou.txt
```

Comprueba nuevamente el resultado:

```
hashcat -m 0 hashes.txt --show
```

Compara los resultados obtenidos con vuestro diccionario y con rockyou.txt. Respondan:

1. ¿Se ha recuperado alguna contraseña que antes no aparecía?
2. ¿Por qué un diccionario grande puede ser más efectivo?
3. ¿Una contraseña larga es necesariamente segura frente a un ataque de diccionario?
4. ¿Qué características debería tener una contraseña para dificultar este tipo de ataque?

Parte 3. Comprobar la seguridad de vuestro propio punto de acceso Wi-Fi

En esta parte comprobaréis la seguridad de una red creada específicamente para la práctica.

1. Crear el punto de acceso

Utilizad el teléfono móvil de uno de los dos miembros de la pareja para crear un punto de acceso Wi-Fi personal (compartir Internet / hotspot). La configuración debe ser exactamente la siguiente:

Parámetro	Valor requerido
SSID	LAB_HASHCAT_GRUPOX (sustituid X por el número de vuestra pareja/grupo)

Seguridad	WPA2-Personal (no uséis WPA3 ni redes abiertas; Hashcat -m 22000 solo cubre WPA/WPA2 con clave PSK)
Banda	2,4 GHz.
Contraseña	Creada exclusivamente para esta práctica.

⚠ No utilizéis la contraseña habitual de vuestro punto de acceso ni de ninguna red real.

2. Conectar un dispositivo

Conectad un segundo dispositivo al punto de acceso del móvil (otro ordenador, otro teléfono o una tablet) y comprobad que la conexión funciona correctamente antes de pasar a la captura.

3. Capturar vuestra propia autenticación Wi-Fi

Desde el equipo Kali Linux, poned el adaptador Wi-Fi en modo monitor:

```
sudo airmon-ng check kill
sudo airmon-ng start wlan0
iwconfig # comprobad que aparece wlan0mon
```

Localizad el canal y el BSSID de vuestro punto de acceso:

```
sudo airodump-ng wlan0mon
```

Lanzad la captura filtrada sobre vuestro propio punto de acceso (sustituid canal y BSSID por los reales):

```
sudo airodump-ng -c <CANAL> --bssid <BSSID_DEL_MOVIL> -w captura wlan0mon
```

Dejad esta captura corriendo en una terminal. Es en este punto donde se produce el ataque de desconexión (deauth), necesario para forzar una nueva autenticación y capturar el handshake sin tener que esperar a que alguien se conecte de forma espontánea.

3.1 Ataque de desconexión (deauth) para forzar el handshake

El objetivo del ataque de desautenticación es enviar tramas de gestión 802.11 falsificadas que hacen creer al dispositivo cliente que el punto de acceso le ha pedido desconectarse. El dispositivo se desconecta automáticamente y, si tiene la red guardada, se vuelve a conectar y a autenticar de inmediato. Esa reconexión es lo que genera el 4-way handshake WPA2 que después atacaréis con Hashcat.

Condiciones necesarias para que el ataque funcione:

- El segundo dispositivo SÍ debe estar conectado al punto de acceso en el momento de lanzar el deauth (o volver a conectarse justo después); si nading está conectado no hay handshake que capturar, porque no se produce ninguna autenticación nueva.
- La captura con airodump-ng (paso anterior) debe estar activa y filtrada sobre el canal y BSSID del punto de acceso, para que registre el handshake en el momento en que se produzca.
- El adaptador de red usado para el deauth debe soportar inyección de paquetes en modo monitor (mismo adaptador que para la captura).
- Debéis conocer la dirección MAC del cliente conectado (aparece en la sección STATION de airodump-ng) y el BSSID del punto de acceso.

En una segunda terminal, con la captura del paso anterior aún en marcha, lanzad el ataque de desconexión dirigido al cliente conectado:

```
sudo aireplay-ng --deauth 5 -a <BSSID_DEL_MOVIL> -c <MAC_DEL_CLIENTE> wlan0mon
```

El parámetro --deauth 5 envía 5 paquetes de desautenticación. En la terminal de airodump-ng debería aparecer, arriba a la derecha, la indicación "WPA handshake:" seguida del BSSID, confirmando que se ha capturado correctamente. Si no aparece, repetid el deauth o comprobad que el dispositivo se ha vuelto a conectar.

⚠ El ataque de desconexión solo debe dirigirse al BSSID y cliente de vuestro propio punto de acceso de laboratorio. Enviar tramas de deauth contra cualquier otra red, propia o ajena, fuera de este ejercicio no está permitido.

Una vez confirmado el handshake, detenid la captura (Ctrl+C en la terminal de airodump-ng). Guardad el archivo generado, por ejemplo:

```
captura.pcapng
```

4. Convertir la captura

Convertid la captura al formato compatible con Hashcat:

```
hcxpcapngtool -o wifi.22000 captura.pcapng
```

Comprobad que se ha generado:

```
wifi.22000
```

5. Ataque con vuestro diccionario

Utilizad Hashcat sobre el archivo obtenido. Para encontrar su contraseña.

Anexo. Alternativa si la tarjeta de red no soporta captura/inyección

No todos los adaptadores Wi-Fi soportan modo monitor e inyección de paquetes (requisito para el ataque de deauth de la Parte 3). Si algún equipo no dispone de un adaptador compatible, existen dos alternativas para poder practicar igualmente con un handshake WPA2 real y con una contraseña conocida de antemano, sin necesidad de capturar tráfico ajeno por el aire.

Existe un archivo adjunto con una captura pcap.

Parte 4. Conclusiones

Respondan brevemente, entre los dos miembros de la pareja:

1. ¿Qué diferencia habéis observado entre utilizar un diccionario pequeño y rockyou.txt?
2. ¿Qué ocurrió cuando la contraseña Wi-Fi estaba incluida en el diccionario?
3. ¿Qué ocurrió cuando no estaba incluida?
4. ¿Por qué Hashcat no "descifra" directamente una contraseña WPA2?
5. ¿Por qué una contraseña poco habitual dificulta un ataque basado únicamente en diccionarios?
6. Proponed una contraseña para el punto de acceso que consideréis más resistente y explicad qué características la hacen mejor.

Entrega

Entregad un único PDF por pareja, con los nombres de ambos integrantes, que incluya:

- Los tres hashes utilizados.
- Una captura de pantalla del contenido de vuestro diccionario.txt.
- Captura de pantalla del ataque con Hashcat de la Parte 1.
- Nombre del SSID creado para la práctica.
- Captura de pantalla del comando de deauth y de la confirmación del handshake en airodump-ng.
- Captura de pantalla del archivo wifi.22000 generado.
- Captura de pantalla del ataque de Hashcat contra vuestro propio punto de acceso.

- Respuestas a todas las preguntas.
- Conclusiones finales.